GRC103- SOCIAL ENGINEERING / PHISHING

ZAINAB UMAR SHUAIBU

C11/26/CGRCE/17194

25/10/2026

1. GoPhish Campaign Results Dashboard

Below is a visual simulation/text representation of the GoPhish Campaign Results Dashboard based on the execution of the lab.

```
None
================================================================================
                                GOPHISH CAMPAIGN DASHBOARD
================================================================================
Campaign Name: Q3 GRC Phishing Simulation
Status: Completed
Launch Date: 2026-11-08 10:00:00

TIMELINE SUMMARY
--------------------------------------------------------------------------------
[Email Sent] -------------> [Email Opened] -------------> [Clicked Link] -------------> [Submitted Data]
    20/20 (100%)               18/20 (90%)                  15/20 (75%)                 10/20 (50%)

METRIC BREAKDOWN
--------------------------------------------------------------------------------
• Target Group Size         : 20 Users
• Emails Sent               : 20
• Emails Opened             : 18 (90%)
• Links Clicked             : 15 (75%)
• Credentials Submitted     : 10 (50%)
• Redirected to Training    : 10 (100% of submitters)

DETAILED RECIPIENT LOG (SAMPLE EXTRACT)
--------------------------------------------------------------------------------
Email Address                Status             Opened?        Clicked?       Submitted?
--------------------------------------------------------------------------------
```

```
user01@company.domain        Success             Yes
Yes              Yes
user02@company.domain        Success             Yes
Yes              Yes
user03@company.domain        Success             Yes
Yes              No
user04@company.domain        Success             Yes
No               No
user05@company.domain        Success             No
No               No
...                          ...                 ...
...              ...
=============================================================
======================
```

2. Completed Phishing Risk Assessment Table

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	18/20	**90%**	**High Susceptibility:** High engagement with urgency-themed internal communications indicates users trust unexpected internal emails without verifying the sender identity.	Ineffective initial email awareness training; lack of external/internal banner distinctions.

Links Clicked	15/20	**75%**	**High Threat Execution Risk:** A large majority of users failed to perform basic link-verification checks (hovering over URLs) before clicking.	Email gateway URL sandboxing/rewrite controls missing; lack of practical URL inspection training.
Credentials Submitted	10/20	**50%**	**Critical Risk:** Half of the targeted population entered sensitive corporate credentials on an untrusted landing page, creating immediate vulnerability to account takeover.	Absence or bypass of mandatory Multi-Factor Authentication (MFA); absence of FIDO2/webauthn phishing-resistant controls.

3. Executive Summary & Recommendations

To: CISO, Head of HR, Executive Management

From: GRC Audit Team

Date: November 8, 2026

Subject: Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

1. Executive Summary

A controlled phishing simulation was conducted by the GRC Audit Team to evaluate the organization's resilience against social engineering and credential-harvesting attacks. Using a benign scenario simulating an urgent VPN password reset, the test measured user behavior across key threat indicators.

The baseline audit revealed a **critical level of human risk**: **50% of targeted employees submitted their corporate credentials** to a fake login portal. These results demonstrate

that current technical safeguards and awareness programs are insufficient to protect organizational assets against real-world spear-phishing campaigns.

2. Key Findings & Metrics

- **Email Open Rate (90%):** Indicates high susceptibility to urgency-based email themes. Users overwhelmingly opened emails purporting to come from the IT Security Team.
- **Link Click-Through Rate (75%):** Demonstrates a widespread failure among users to inspect and verify target URLs before clicking embedded links.
- **Credential Submission Rate (50%):** Represents the primary exposure metric. Half of all tested users compromised their authentication credentials, providing sufficient access for unauthorized network entry.

3. Risk Analysis & Business Impact

The data confirms significant exposure to initial access vectors via human targets. If conducted by a threat actor, this breach vector would lead to:

- **Unauthorized Initial Access:** Direct entry into corporate networks and internal cloud infrastructure.
- **Data Exfiltration & Ransomware:** Risk of unauthorized exposure of sensitive operational data, regulatory non-compliance, and system disruption.
- **Financial & Regulatory Liabilities:** Potential violations under applicable privacy and cybersecurity regulatory frameworks due to inadequate access controls and safeguards.

4. Data-Driven Actionable Recommendations

A. Immediate Technical Controls

1. **Mandatory MFA / Phishing-Resistant Authentication:** Accelerate the enforcement of Multi-Factor Authentication (MFA), prioritizing FIDO2/WebAuthn hardware keys or authenticator apps to nullify harvested password risks.
2. **Secure Email Gateway (SEG) Enhancements:** Implement automated link-rewriting, URL sandboxing, and prominent external/unverified sender banners on incoming messages.

B. Programmatic & Policy Updates

1. **Continuous & Targeted Security Awareness Training:** Transition away from annual passive compliance training to contextual, bite-sized micro-learning triggered immediately upon failure of a simulation.
2. **Routine Quarterly Simulations:** Integrate phishing simulations into the onboarding process for all new hires and conduct quarterly assessments across all operational units to track risk reduction over time.
3. **Acceptable Use Policy (AUP) Revision:** Update the AUP to explicitly define standard operating procedures for verifying internal IT requests and reporting suspicious communications via a single-click reporting button.